

Gestion des risques

*Application du NIST Cybersecurity Framework 2.0 dans un centre
d'imagerie médicale*



Réaliser par:

**Hayat Bouchra
Alioua Malak Elferdouas
Bahalloul Hamza**

Encadré par :

Prof. Ali Kartit

Contents

Abstract	2
1 Introduction	3
1.1 1.1 Contexte General	3
1.2 1.2 Importance de la cybersécurité en imagerie médicale	3
1.3 1.3 Le NIST CSF 2.0 comme cadre de référence	4
2 Présentation du NIST Cybersecurity Framework 2.0	5
2.1 2.1 Qu'est-ce que le cadre NIST Cybersecurity Framework (CSF) ?	5
2.2 2.2 Histoire du cadre de cybersécurité du NIST	5
2.3 2.3 Fonctions principales du cadre de cybersécurité du NIST	6
2.4 2.4 Concepts clés de l'analyse des risques	7
2.5 2.5 Justification du choix du NIST CSF 2.0 pour le secteur médical	8
3 Mise en œuvre du NIST CSF 2.0 : déroulement des ateliers d'analyse des risques	9
3.1 3.1 Atelier 1 – Contexte et périmètre du centre d'imagerie médicale	9
3.1.1 3.1.1 Description générale de l'établissement	9
3.1.2 3.1.2 Processus métiers critiques	10
3.1.3 3.1.3 Enjeux de sécurité spécifiques	10
3.2 3.2 Atelier 2 - Identification et Cartographie des Actifs	10
3.3 3.3 Atelier 3 — Identification des Menaces et Vulnérabilités	11
3.4 3.4 Atelier 4 — Évaluation et Hiérarchisation des Risques	13
3.4.1 3.4.1 Méthodologie d'évaluation	13
3.4.2 3.4.2 Interprétation des résultats	13
3.5 3.5 Atelier 5 — Traitement des Risques selon le NIST CSF 2.0	14
3.6 3.6 Atelier 6 — Plan de Sécurité et Priorisation	16
3.7.1 3.6.1 Actions prioritaires à court terme (0-3 mois)	18
3.7.2 3.6.2 Actions structurantes à moyen terme (3-12 mois)	18
3.7.3 3.6.3 Maturité et amélioration continue à long terme (12-24 mois)	18
4 Conclusion	19
4.1 4.1 Synthèse des résultats	19
4.2 4.2 Apport du NIST CSF 2.0 dans la gestion des risques médicaux	19
4.3 4.3 Perspectives d'amélioration continue	19
5 References	21

Resumé

This report presents a comprehensive study of ethical hacking a discipline in which cybersecurity professionals use the same tools and methodologies as malicious attackers to expose and remediate security vulnerabilities before they can be exploited. The project encompasses both a rigorous theoretical framework and a controlled hands-on demonstration conducted in an isolated virtual environment at ENSA El Jadida, under the supervision of Prof. Remch Abdelghani.

Our team investigated the full attack lifecycle, covering the five structured phases of ethical hacking: reconnaissance, scanning and enumeration, exploitation, post-exploitation, and covering tracks. Alongside this methodology, we examined the most prevalent attack types in today's threat landscape, including SQL injection, man-in-the-middle attacks, phishing, ransomware, DDoS, and cross-site scripting, among others. We also compiled a reference of fifty industry-standard tools spanning ten categories from network scanning and web application testing to password cracking, wireless security, and digital forensics.

The primary objective of this work was to understand how attackers identify and leverage system weaknesses and, critically, how defenders can use that same knowledge to strengthen their security postures. Our analysis underscores the indispensable role of ethical hacking in modern cybersecurity not as an offensive discipline, but as a proactive and legally grounded strategy for protecting systems, data, and users. The report concludes with a set of actionable security recommendations derived from the attack vectors examined throughout the study.

Introduction

1.1 Contexte General

Le secteur de la santé connaît depuis deux décennies une transformation numérique profonde et irréversible. L'adoption massive des systèmes d'information hospitaliers (SIH), des dossiers médicaux électroniques (DME), des équipements médicaux connectés et des plateformes de télémédecine a considérablement amélioré la qualité et l'efficacité des soins prodigués aux patients. Cette révolution numérique touche plus particulièrement les centres d'imagerie médicale, qui constituent aujourd'hui des nœuds critiques du système de santé.

Les centres d'imagerie médicale regroupent des équipements hautement sophistiqués tels que les scanners à tomodensitométrie (TDM), les machines d'Imagerie par Résonance Magnétique (IRM), les systèmes d'échographie numérique, les appareils de radiologie numérique directe (RNI) et les équipements de médecine nucléaire (TEP-Scan). Ces dispositifs génèrent, traitent et transmettent quotidiennement des volumes considérables de données médicales sensibles, notamment des images DICOM (Digital Imaging and Communications in Medicine), des rapports radiologiques et des métadonnées patients.

L'interconnexion croissante de ces systèmes au sein de réseaux étendus, leur intégration dans des architectures cloud hybrides et leur communication avec des systèmes tiers (laboratoires, pharmacies, établissements partenaires) ont multiplié les surfaces d'attaque potentielles. Selon le rapport annuel du Ponemon Institute (2023), le secteur de la santé enregistre le coût moyen de violation de données le plus élevé de tous les secteurs industriels, dépassant 10,9 millions de dollars par incident, une réalité particulièrement préoccupante pour les structures d'imagerie médicale.

1.2 Importance de la cybersécurité en imagerie médicale

La cybersécurité dans les centres d'imagerie médicale revêt une importance capitale qui transcende la simple protection des actifs informatiques. Elle englobe en réalité trois dimensions fondamentales et indissociables : la protection des données à caractère personnel et médical des patients, la disponibilité continue des systèmes nécessaires au diagnostic et au traitement, et l'intégrité des images et rapports médicaux sur lesquels reposent les décisions cliniques.

Sur le plan juridique et réglementaire, les centres d'imagerie opèrent dans un cadre normatif strict. En Europe, le Règlement Général sur la Protection des Données (RGPD) impose des obligations de sécurité renforcées pour les données de santé, qualifiées de « données sensibles » au sens de l'article 9. La directive NIS2 (Network and Information Security 2), entrée en vigueur en octobre 2024, classe les établissements de santé comme des entités essentielles soumises à des exigences de sécurité et de reporting d'incidents élevées. En France spécifiquement, la doctrine de la CNIL et les recommandations de l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information) définissent des obligations précises pour les systèmes d'information de santé (SIS).

La réalité des cybermenaces pesant sur le secteur médical est illustrée par plusieurs incidents majeurs récents. En 2020, l'attaque par ransomware contre le Centre Hospitalier de Rouen a paralysé l'ensemble du système d'information pendant plusieurs semaines, contraignant le personnel à revenir au fonctionnement sur papier et reportant des actes médicaux critiques. En 2021, le groupe AP-HP (Assistance Publique - Hôpitaux de Paris) a subi une exfiltration massive de données affectant 1,4 million de patients. Ces exemples illustrent concrètement les enjeux vitaux liés à la cybersécurité des infrastructures de santé

1.3 Le NIST CSF 2.0 comme cadre de référence

Le National Institute of Standards and Technology Cybersecurity Framework (NIST CSF), dans sa version 2.0 publiée en février 2024, constitue aujourd'hui l'un des référentiels les plus reconnus et les plus utilisés en matière de gestion de la cybersécurité au niveau mondial. Initialement développé pour les infrastructures critiques américaines à la suite du décret exécutif 13636 signé par le président Obama en 2013, le framework a connu une adoption internationale progressive et a été étendu à tous les secteurs d'activité dans sa version 2.0.

La pertinence du NIST CSF 2.0 pour un centre d'imagerie médicale repose sur plusieurs facteurs. D'abord, sa structure modulaire en six fonctions (Govern, Identify, Protect, Detect, Respond, Recover) offre une vision holistique et complète du cycle de vie de la gestion des risques. Ensuite, son caractère non prescriptif permet une adaptation aux spécificités organisationnelles et réglementaires propres à chaque établissement de santé. Enfin, sa compatibilité avec d'autres standards reconnus tels que l'ISO/IEC 27001, l'ISO 27005 et HIPAA facilite son intégration dans des démarches de conformité existantes.

Présentation du NIST Cybersecurity Framework 2.0

2.1 Qu'est-ce que le cadre NIST Cybersecurity Framework (CSF) ?

Le cadre de cybersécurité du NIST est un ensemble de lignes directrices, de normes et de bonnes pratiques publié par le National Institute of Standards and Technology (NIST) des États-Unis pour aider les organisations à atténuer les risques en matière de cybersécurité. Il s'agit d'un cadre volontaire qui fournit aux organisations une structure de bonnes pratiques afin de mieux comprendre, gérer et réduire leurs risques en cybersécurité, ainsi que de protéger leurs réseaux et leurs données.

Ce cadre est un document évolutif, mis à jour et amélioré au fil du temps pour suivre les évolutions technologiques et les menaces en cybersécurité, tout en intégrant les meilleures pratiques et les enseignements tirés. Il repose sur cinq domaines clés : identifier, protéger, détecter, répondre et récupérer. Il est largement considéré comme la référence pour la mise en place d'un programme de cybersécurité.

L'objectif du cadre est d'aider les organisations à hiérarchiser leurs investissements et leurs décisions en cybersécurité, à évaluer leur maturité en la matière et à fournir une base de discussion avec les parties prenantes, y compris la direction et le conseil d'administration.

2.2 Histoire du cadre de cybersécurité du NIST

Le cadre de cybersécurité du NIST a été établi en réponse au décret exécutif 13636, « Amélioration de la cybersécurité des infrastructures critiques », publié le 12 février 2013. Ce décret a initié la collaboration du NIST avec le secteur privé américain afin de définir des normes consensuelles volontaires et des meilleures pratiques industrielles pouvant être intégrées dans un cadre de cybersécurité adapté. Cette collaboration a abouti à la publication de la première version du cadre de cybersécurité du NIST.

- **Version 1.0** : La version initiale du cadre de cybersécurité du NIST a été publiée en février 2014 en réponse au décret exécutif 13636. Elle a posé les bases du cadre en fournissant un ensemble complet de lignes directrices et de bonnes pratiques pour la gestion des risques en cybersécurité.
- **Version 1.1** : En avril 2018, le NIST a publié la version 1.1 du cadre de cybersécurité, marquant une avancée significative par rapport à la version originale. Cette mise à jour a affiné, clarifié et amélioré la version 1.0, la rendant plus flexible pour répondre aux besoins spécifiques des organisations et applicable à un large éventail d'environnements technologiques, notamment les systèmes de contrôle industriel, les technologies de l'information et l'Internet des objets.
- **Version 2.0** : En 2023, le NIST a publié un projet de la version 2.0 du cadre de cybersécurité pour consultation publique. Cette nouvelle étape marque une évolution importante du cadre, avec des mises à jour potentielles significatives. Le développement de la version 2.0 reflète l'engagement continu du NIST à maintenir le cadre pertinent et efficace face aux défis croissants de la cybersécurité.

Ces différentes versions illustrent l'adaptabilité et la réactivité du cadre face à l'évolution constante des menaces et des technologies en cybersécurité, garantissant ainsi qu'il reste une ressource précieuse pour les organisations cherchant à renforcer leur posture en matière de cybersécurité.

2.3 Fonctions principales du cadre de cybersécurité du NIST

Le cadre de cybersécurité du NIST repose sur des fonctions essentielles qui offrent une approche globale pour gérer et prévenir les risques en cybersécurité.

- **GOVERNER (GV)** — La stratégie, les attentes et la politique de gestion des risques de cybersécurité de l'organisation sont établies, communiquées et surveillées. La Fonction **gouverner** fournit des résultats pour informer ce qu'une organisation peut faire pour atteindre et prioriser les résultats des cinq autres Fonctions dans le contexte de sa mission et des attentes des parties prenantes. Les activités de gouvernance sont essentielles pour intégrer la cybersécurité dans la stratégie plus large de gestion des risques d'entreprise (ERM) d'une organisation. Gouverner aborde la compréhension du contexte organisationnel ; l'établissement d'une stratégie de cybersécurité et de gestion des risques de la chaîne d'approvisionnement en cybersécurité; les rôles, les responsabilités et les autorités; la politique; et la supervision de la stratégie de cybersécurité.
- **IDENTIFIER (ID)** — Les risques de cybersécurité actuels de l'organisation sont compris. La compréhension des actifs de l'organisation (p. ex., données, matériel, logiciels, systèmes, installations, services, personnes), des fournisseurs et des risques de cybersécurité associés permet à une organisation de prioriser ses efforts en cohérence avec sa stratégie de gestion des risques et aux besoins de la mission identifiés sous gouverner. Cette Fonction comprend également l'identification des opportunités d'amélioration des politiques, plans, processus, procédures et pratiques de l'organisation qui soutiennent la gestion des risques de cybersécurité afin d'éclairer les efforts dans le cadre des six Fonctions.
- **PROTEGER (PR)** — Des mesures de protection sont utilisées pour gérer les risques de cybersécurité de l'organisation. Une fois les actifs et les risques identifiés et priorisés, **protéger** prend en charge la capacité à sécuriser ces actifs pour prévenir ou réduire la probabilité et l'impact d'événements de cybersécurité indésirables, ainsi que pour augmenter la probabilité et l'impact de tirer parti des opportunités. Les résultats couverts par cette Fonction comprennent la gestion des identités, l'authentification et le contrôle d'accès ; la sensibilisation et la formation ; la sécurité des données; la sécurité de la plateforme (c.-à-d. la sécurisation du matériel, des logiciels et des services des plateformes physiques et virtuelles) ; et la résilience de l'infrastructure technologique.
- **DETECTER (DE)** — Les attaques et compromissions de cybersécurité possibles sont détectées et analysées. Detecter permet la découverte et l'analyse en temps opportun des anomalies, des indicateurs de compromission et d'autres événements potentiellement indésirables qui peuvent indiquer que des attaques et des incidents de cybersécurité se produisent. Cette Fonction prend en charge les activités réussies de réponse aux incidents et de récupération.
- **REPONDRE (RS)** — Des mesures concernant un incident de cybersécurité détecté sont prises. Répondre soutient la capacité à contenir les effets des incidents de cybersécurité. Les résultats au sein de cette Fonction couvrent la gestion, l'analyse, l'atténuation, la production de rapports et la communication des incidents
- **RECUPERER (RC)** — Les actifs et les opérations affectés par un incident de cybersécurité sont restaurés. Recuperer prend en charge la restauration rapide des opérations normales afin de réduire les effets des incidents de cybersécurité et de permettre une communication appropriée pendant les efforts de récupération.

Function	Category	Category Identifier
Govern (GV)	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Cybersecurity Supply Chain Risk Management	GV.SC
	Roles, Responsibilities, and Authorities	GV.RR
	Policies, Processes, and Procedures	GV.PO
	Oversight	GV.OV
Identify (ID)	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM
Protect (PR)	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
Detect (DE)	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
Respond (RS)	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
Recover (RC)	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO



Figure 1: Fonctionnalité NIST cybersec Framework

2.4 Concepts clés de l'analyse des risques

La mise en œuvre efficace du NIST CSF 2.0 nécessite la maîtrise d'un vocabulaire conceptuel précis et partagé par l'ensemble des parties prenantes. Le tableau ci-dessous synthétise les cinq concepts fondamentaux de l'analyse des risques dans le contexte de l'imagerie médicale.

Concept	Définition formelle	Exemple en imagerie médicale
Actif	Tout élément ayant de la valeur pour l'organisation et devant être protégé.	Serveur PACS contenant les archives radiologiques des 10 dernières années.
Menace	Source ou agent potentiel susceptible d'exploiter une vulnérabilité et de causer un préjudice.	Un groupe de cybercriminels déployant un ransomware pour chiffrer les données DICOM.
Vulnérabilité	Faiblesse ou lacune dans un système pouvant être exploitée par une menace.	Absence de correctif de sécurité sur un équipement IRM fonctionnant sous Windows 7.
Impact	Conséquence effective ou potentielle de la matérialisation d'un risque sur l'organisation.	Indisponibilité du scanner TDM pendant 72 heures, reports d'examens urgents.
Risque	Combinaison de la probabilité qu'une menace exploite une vulnérabilité et de l'impact résultant.	Risque élevé de compromission du réseau DICOM par intrusion via un équipement non patché.

La notion de risque, concept central de la démarche, peut être formalisée mathématiquement de la façon suivante : $R = P \times I$, où P désigne la probabilité d'occurrence de l'événement redouté (exploitation de la vulnérabilité par la menace) et I représente l'impact estimé sur les objectifs de l'organisation (disponibilité, intégrité, confidentialité des actifs concernés). Cette formulation simple permet une hiérarchisation comparative des risques identifiés et facilite la priorisation des mesures de traitement.

2.5 Justification du choix du NIST CSF 2.0 pour le secteur médical

Plusieurs raisons fondées justifient le choix du NIST CSF 2.0 comme cadre de référence pour la gestion des risques cybersécuritaires d'un centre d'imagerie médicale. Premièrement, sa reconnaissance internationale en fait un standard crédible et auditable, facilitant la communication avec les tutelles, les assureurs et les partenaires. Deuxièmement, sa compatibilité explicite avec HIPAA (Health Insurance Portability and Accountability Act), référentiel de sécurité de la santé américain, et son alignement avec les exigences européennes du RGPD et de la directive NIS2, en font un cadre particulièrement adapté aux structures de santé.

Troisièmement, l'approche orientée risques du NIST CSF 2.0, fondée sur la notion de profil cible et de profil actuel, permet de définir des feuilles de route de sécurisation progressives et réalistes, compatibles avec les contraintes budgétaires des établissements de santé. Quatrièmement, l'intégration de la nouvelle fonction GOVERN dans la version 2.0 répond directement aux lacunes identifiées dans de nombreux établissements de santé en matière de gouvernance et de responsabilisation au niveau de la direction. Enfin, la disponibilité de profils sectoriels communautaires (Community Profiles) développés spécifiquement pour le secteur de la santé facilite l'adaptation et la mise en œuvre du framework.

Mise en œuvre du NIST CSF 2.0 : déroulement des ateliers d'analyse des risques

Le travail pratique d'analyse des risques est présenté sous forme de six ateliers progressifs et inter-dépendants. Cette approche par ateliers, inspirée des méthodologies professionnelles de gestion des risques (notamment EBIOS Risk Manager de l'ANSSI), permet une démarche structurée, collaborative et documentée, impliquant l'ensemble des parties prenantes de l'établissement.

3.1 Atelier 1 – Contexte et périmètre du centre d'imagerie médicale

3.1.1 Description générale de l'établissement

Le centre d'imagerie médicale objet de cette étude est un établissement privé de taille intermédiaire disposant de l'équipement suivant : deux scanner à tomodensitométrie (TDM) de dernière génération, une machine d'IRM 3 Tesla, trois tables de radiologie numérique directe (DR), une salle d'échographie dédiée, et un équipement de mammographie numérique.

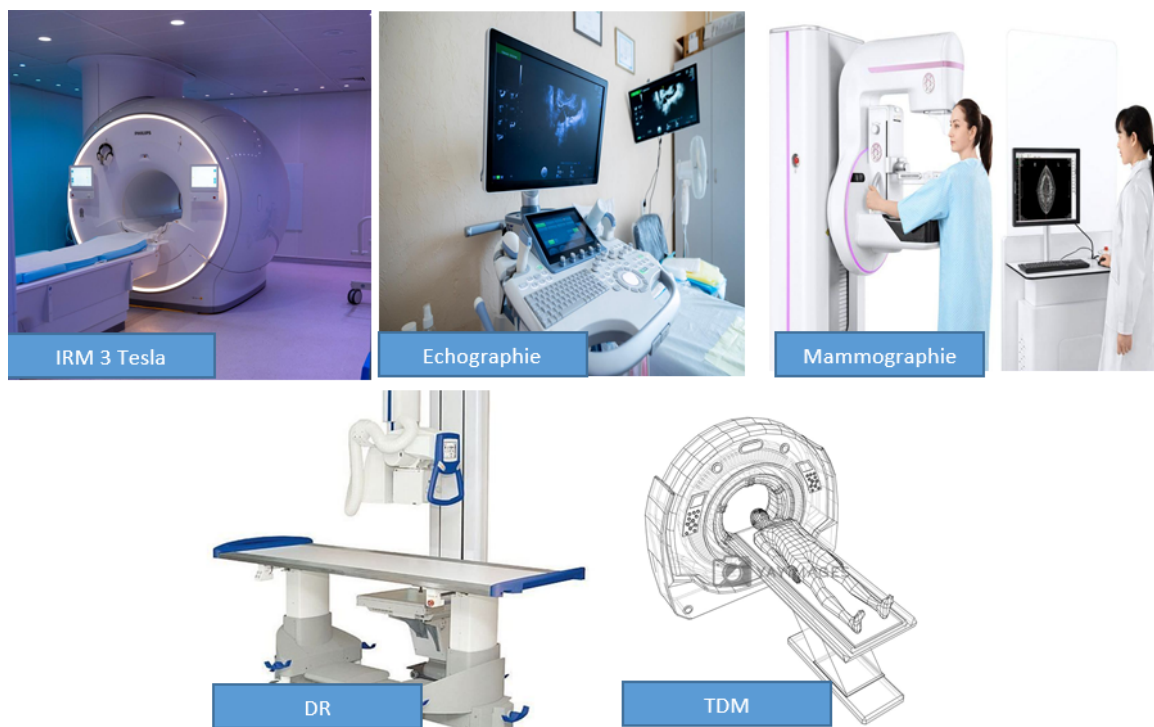


Figure 2: équipement du centre médicale

Le centre emploie une équipe pluridisciplinaire composée de :

- 4 **médecins radiologues** spécialisés ;
- 8 **manipulateurs en électroradiologie médicale** ;
- 3 **secrétaires médicales** ;
- 1 **technicien informatique** responsable du SI.

Le centre traite en moyenne 150 examens par jour, générant environ 80 Go de données DICOM quotidiennement. Il est connecté à deux cliniques partenaires et à un service de téléradiologie pour les gardes nocturnes et weekends.

3.1.2 Processus métiers critiques

L'analyse des processus métiers du centre permet d'identifier les flux d'information critiques qui doivent être protégés en priorité. Les principaux processus sont les suivants :

- **Prise en charge patient** : accueil administratif, vérification des prescriptions médicales, enregistrement dans le DPI et le RIS, collecte du consentement éclairé.
- **Acquisition des images** : réalisation de l'examen par le manipulateur, acquisition et transfert automatique des images vers le PACS via le protocole DICOM.
- **Interprétation et compte rendu** : visualisation des images par le radiologue sur des stations PACS dédiées, rédaction du compte rendu dans le RIS, signature électronique et envoi au médecin prescripteur via messagerie sécurisée de santé (MSSanté).
- **Téléradiologie** : transfert chiffré des images vers la plateforme de téléradiologie via VPN dédié, interprétation à distance, retour du compte rendu signé électroniquement.
- **Archivage et traçabilité** : archivage long terme des images dans le PACS (conservation réglementaire de 10 ans minimum), journalisation des accès et des actions utilisateurs.
- **Administration et facturation** : gestion des rendez-vous, facturation, transmission des feuilles de soins électroniques (FSE) à l'Assurance Maladie.

3.1.3 Enjeux de sécurité spécifiques

Le centre d'imagerie médicale est soumis à des contraintes de sécurité spécifiques qui découlent directement de son activité :

- **Exigences réglementaires** : application du RGPD (données de santé = catégorie spéciale), certification HDS pour l'hébergement des données patients, respect des obligations de notification à la CNIL en cas de violation de données.
- **Contraintes de disponibilité** : la disponibilité des systèmes est critique pour la prise en charge des patients (urgences radiologiques). Une interruption prolongée peut mettre des vies en danger.
- **Intégrité des images médicales** : toute altération des images diagnostiques pourrait conduire à une erreur diagnostique avec des conséquences médicales graves. L'intégrité des données est un enjeu vital.
- **Équipements biomédicaux connectés** : les scanners, IRM et autres équipements fonctionnent sous des systèmes d'exploitation souvent obsolètes (Windows 7/10 embarqué) qui ne peuvent pas toujours être mis à jour sans validation préalable du fabricant.

3.2 Atelier 2 - Identification et Cartographie des Actifs

L'identification exhaustive des actifs constitue le prérequis fondamental de toute démarche de gestion des risques. Elle s'inscrit directement dans la fonction Identify du NIST CSF 2.0. Le tableau suivant présente les actifs critiques du centre d'imagerie médicale, classés par catégorie et évalués selon leur criticité (de 1 = faible à 5 = critique) :

L'analyse de cet inventaire met en évidence quatre actifs d'une criticité maximale (score 5) : le PACS, les équipements d'imagerie, le DPI et le RIS. Ces systèmes constituent le cœur opérationnel du centre et représentent les cibles prioritaires pour tout attaquant souhaitant perturber l'activité ou exfiltrer des données sensibles. La protection de ces actifs doit faire l'objet de mesures de sécurité renforcées, constituant les priorités absolues du plan de sécurité.

Actif	Catégorie	Rôle / Fonction	Criticité	Score
PACS (Picture Archiving and Communication System)	Logiciel appli-catif	Stockage et accès aux images médicales DICOM	Critique	5
Scanner IRM / Scanner CT / Mammographe	Matériel médical	Acquisition des images diagnostiques	Critique	5
Dossier Patient Informatisé (DPI)	Données / Appli-cation	Historique médical, ordonnances, résultats	Critique	5
RIS (Radiology Information System)	Logiciel appli-catif	Gestion des rendez-vous et comptes rendus	Critique	5
Réseau LAN / Wi-Fi interne	Infrastructure réseau	Interconnexion des équipements et systèmes	Élevé	4
Serveurs de stockage (NAS/SAN)	Infrastructure IT	Archivage images et données patients	Critique	5
Postes de travail radiologues / techniciens	Matériel IT	Accès et interprétation des images	Élevé	4
Systèmes de sauvegarde	Infrastructure IT	Continuité et reprise d'activité	Élevé	4
Données d'identification patients	Données	Identité, coordonnées, numéro de sécurité sociale	Critique	5
Personnel médical et administratif	Humain	Utilisation et accès aux systèmes	Élevé	4
Connexion Internet / VPN téléradiologie	Réseau externe	Transmission sécurisée des images	Élevé	4
Logiciels de cybersécurité (antivirus, SIEM)	Logiciel sécurité	Protection et surveillance des systèmes	Moyen	3

Table 1: Inventaire des actifs critiques du centre d'imagerie médicale

3.3 Atelier 3 — Identification des Menaces et Vulnérabilités

Cette étape s'inscrit dans les fonctions Identify et Detect du NIST CSF 2.0. Elle vise à cartographier de manière systématique l'ensemble des menaces pesant sur le centre d'imagerie, en les associant aux vulnérabilités susceptibles d'être exploitées. Cette analyse se fonde sur les retours d'expérience des incidents de cybersécurité dans le secteur de la santé (CERT Santé, ANSSI) ainsi que sur les données épidémiologiques des cybermenaces publiées par l'ENISA (European Union Agency for Cybersecurity).

Menace identifiée	Type	Vulnérabilité exploitée	Impact potentiel	Sévérité
Attaque par ransomware (ex : WannaCry, Ryuk)	Malveillance externe	Absence de mise à jour des systèmes, OS obsolètes	Confidentialité, Disponibilité	Critique
Exfiltration de données patients (DPI/-PACS)	Malveillance externe/interne	Contrôle d'accès insuffisant, absence de chiffrement	Confidentialité	Critique
Accès non autorisé aux dossiers médicaux	Interne / externe	Gestion des privilèges défaillante, MFA absent	Confidentialité, Intégrité	Élevé
Attaque sur les équipements d'imagerie connectés	Malveillance externe	Protocoles DICOM non sécurisés, firmware obsolète	Disponibilité, Intégrité	Élevé
Phishing / ingénierie sociale ciblant le personnel	Malveillance externe	Manque de formation des utilisateurs, filtrage e-mail insuffisant	Confidentialité, Disponibilité	Élevé
Panne matérielle des serveurs de stockage	Accident / défaillance	Absence de redondance, plan de sauvegarde inadéquat	Disponibilité	Moyen
Interception des transmissions de téléradiologie	Malveillance externe	Chiffrement TLS absent ou mal configuré sur VPN	Confidentialité, Intégrité	Élevé
Erreur humaine (suppression de données, mauvaise configuration)	Erreur interne	Absence de contrôle de version, sauvegardes insuffisantes	Disponibilité, Intégrité	Moyen
Déni de service (DDoS/DDoS) sur l'infrastructure réseau	Malveillance externe	Absence de pare-feu applicatif, bande passante limitée	Disponibilité	Moyen
Compromission d'un compte administrateur	Malveillance externe/interne	Mots de passe faibles, absence de gestion des accès privilégiés	Confidentialité, Intégrité, Disponibilité	Critique

Table 2: Cartographie des menaces et vulnérabilités associées

L'analyse de ce tableau révèle que les menaces les plus sévères convergent vers les systèmes de gestion des données patients (PACS, DPI) et les infrastructures d'authentification. Le ransomware représente la menace la plus critique par sa combinaison d'une probabilité d'occurrence élevée (les établissements de santé sont des cibles privilégiées des groupes cybercriminels) et d'un impact potentiellement catastrophique sur la continuité des soins.

3.4 Atelier 4 — Évaluation et Hiérarchisation des Risques

3.4.1 Méthodologie d'évaluation

L'évaluation des risques est conduite selon la méthode qualitative semi-quantitative classique, consistant à calculer pour chaque scénario de risque le produit de sa probabilité d'occurrence par son impact potentiel. Les deux paramètres sont évalués sur une échelle de 1 à 5 :

- **Probabilité (P)** : 1 = très improbable, 2 = improbable, 3 = possible, 4 = probable, 5 = très probable.
- **Impact (I)** : 1 = négligeable, 2 = mineur, 3 = modéré, 4 = majeur, 5 = critique/catastrophique.
- Score de risque = $P \times I$, avec une échelle interprétative : 1-4 = Faible, 5-9 = Moyen, 10-15 = Élevé, 16-25 = Critique.

Scénario de risque	P	I	Score $P \times I$	Niveau	Conséquence principale
Attaque ransomware sur PACS/DPI	4	5	20	Critique	Chiffrement complet des données patients, arrêt des services médicaux
Exfiltration données patients	3	5	15	Critique	Violation RGPD, perte de confiance, amendes, atteinte à la vie privée
Compromission compte administrateur	3	5	15	Critique	Contrôle total de l'infrastructure par l'attaquant
Accès non autorisé dossiers médicaux	3	4	12	Élevé	Atteinte à la confidentialité médicale, sanctions légales
Attaque équipements imagerie connectés	2	4	8	Élevé	Indisponibilité des équipements, risque patient, délais diagnostiques
Phishing ciblant le personnel	4	3	12	Élevé	Compromission de comptes, propagation de malwares
Interception transmissions téléradiologie	2	4	8	Élevé	Fuite d'images médicales sensibles pendant le transfert
DoS / DDoS réseau	2	4	8	Moyen	Interruption temporaire des services de planification
Panne serveur stockage	2	4	8	Moyen	Indisponibilité des images archivées, retard diagnostique
Erreur humaine (suppression données)	3	3	9	Moyen	Perte temporaire de données, reprise sur sauvegarde nécessaire

Table 3: Matrice d'évaluation des risques ($P \times I$)

3.4.2 Interprétation des résultats

L'analyse de la matrice de risques révèle trois risques de niveau Critique (score 16) : l'attaque par ransomware sur les systèmes PACS/DPI, l'exfiltration de données patients, et la compromission d'un compte administrateur. Ces risques doivent faire l'objet d'une attention prioritaire et

de mesures de traitement immédiates. Cinq risques de niveau Élevé (score 8-12) nécessitent également des actions à court terme, notamment les attaques ciblant les équipements d'imagerie connectés, les campagnes de phishing, et les risques d'interception des transmissions de téléradiologie. Enfin, trois risques de niveau Moyen représentent des préoccupations à adresser à moyen terme, dans le cadre du plan de sécurité global. Il est important de noter que cette évaluation constitue une photographie de l'état des risques à un instant donné. Le paysage des cybermenaces évoluant rapidement, cette analyse devra être réévaluée au minimum annuellement, ou à l'occasion de tout changement significatif dans l'environnement technique ou organisationnel du centre.

3.5 Atelier 5 — Traitement des Risques selon le NIST CSF 2.0

Le traitement des risques consiste à sélectionner et à mettre en œuvre des mesures de sécurité visant à réduire les risques identifiés à un niveau acceptable, défini par la direction du centre (appétence au risque). Le NIST CSF 2.0 fournit un cadre structurant pour associer chaque risque aux fonctions et sous-catégories de contrôles les plus pertinents. Pour chaque risque, quatre stratégies de traitement sont possibles : accepter (le risque est jugé acceptable en l'état), éviter (supprimer l'activité source de risque), transférer (souscrire une assurance cyber ou externaliser), ou réduire (mettre en œuvre des contrôles de sécurité).

Risque	Niveau	Fonction NIST	Mesures de sécurité proposées	Terme*
Ransomware (PACS/DPI)	Critique	Protect / Recover	Segmentation réseau, sauvegardes hors ligne testées, EDR sur tous les postes, plan PRA validé	C/T
Exfiltration données	Critique	Protect / Detect	Chiffrement AES-256 des données au repos et en transit, DLP, SIEM avec alertes d'exfiltration	C/T
Compromission compte admin	Critique	Govern / Protect	PAM (Privileged Access Management), MFA obligatoire, revue trimestrielle des droits	C/T
Accès non autorisé dossiers	Élevé	Protect / Detect	RBAC granulaire, journalisation des accès, audit annuel, traçabilité des consultations DPI	C/M
Attaque équipements imagerie	Élevé	Identify / Protect	Inventaire des équipements DICOM, VLAN dédié, mise à jour firmware, désactivation ports inutilisés	M/L
Phishing personnel	Élevé	Govern / Protect	Campagnes de sensibilisation trimestrielles, filtrage e-mail (SPF/DKIM/DMARC), simulation d'attaques	C/T
Interception téléradiologie	Élevé	Protect	VPN avec TLS 1.3, PKI interne, certificats numériques, audit des flux réseau	C/M
DoS / DDoS réseau	Moyen	Protect / Respond	Firewall applicatif (WAF), QoS, plan de communication de crise défini	M
Panne serveur stockage	Moyen	Recover	RAID 6, sauvegarde 3-2-1 (local, distant, cloud), RTO < 4h défini contractuellement	M
Erreur humaine	Moyen	Govern / Recover	Procédures documentées, contrôle de version, formation continue du personnel	C/M

Table 4: Plan de traitement des risques aligné sur les fonctions NIST CSF 2.0

*Terme : C = Court terme (0-3 mois), M = Moyen terme (3-12 mois), L = Long terme (12-24 mois), T = Traitement technique requis en urgence.

L'analyse de ce tableau de traitement met en évidence la prédominance des fonctions Protect et Govern dans le traitement des risques les plus critiques. Cela traduit la nécessité, pour le centre d'imagerie, d'investir en priorité dans des mesures préventives solides (contrôle des accès, chiffrement, segmentation réseau) et dans la mise en place d'une gouvernance de la cybersécurité formalisée, plutôt que de se limiter à des outils réactifs

3.6 Atelier 6 — Plan de Sécurité et Priorisation

Le plan de sécurité synthétise l'ensemble des décisions de traitement des risques en un programme d'actions opérationnel, hiérarchisé selon trois horizons temporels. Cette feuille de route constitue le livrable central de la démarche de gestion des risques : elle permet d'aligner les investissements en cybersécurité sur les risques prioritaires et de rendre compte des progrès réalisés à la direction du centre.

Horizon	Action prioritaire	Responsable	Indicateur de succès	Priorité
Court terme (0-3 mois)	Déploiement MFA pour tous les accès critiques (PACS, DPI, Admin)	DSSI / IT	MFA actif sur 100% des comptes critiques	Élevé
Court terme (0-3 mois)	Revue et cloisonnement des droits d'accès (RBAC + PAM)	DSSI / DRH	Droits réduits au strict nécessaire	Élevé
Court terme (0-3 mois)	Test et validation du plan de sauvegarde et de restauration (PRA)	IT	RTO < 4h validé en conditions réelles	Critique
Court terme (0-3 mois)	Campagne de sensibilisation phishing pour tout le personnel	RSSI / RH	Taux de clics < 5% aux simulations	Élevé
Moyen terme (3-12 mois)	Déploiement d'un SIEM (Security Information and Event Management)	IT / RSSI	Tableaux de bord sécurité opérationnels	Élevé
Moyen terme (3-12 mois)	Segmentation VLAN des équipements d'imagerie médicale	IT réseau	0 communication directe équipements/Internet	Moyen
Moyen terme (3-12 mois)	Chiffrement systématique des données patients au repos et en transit	IT / DSSI	100% des flux chiffrés en TLS 1.3	Critique
Moyen terme (3-12 mois)	Audit de sécurité et test d'intrusion (pentest) externe	Prestataire	Rapport pentest sans faille critique	Élevé
Long terme (12-24 mois)	Certification ISO 27001 du système d'information de santé	Direction / RSSI	Certification obtenue	Moyen
Long terme (12-24 mois)	Mise en place d'un programme de gestion des vulnérabilités (VM)	IT / RSSI	Vulnérabilités critiques corrigées < 72h	Moyen
Long terme (12-24 mois)	Tableau de bord sécurité et reporting trimestriel à la direction	RSSI	KPI sécurité intégrés au comité de pilotage	Moyen

Table 5: Plan d'action sécurité priorisé (Court / Moyen / Long terme)

Ce plan d'action a été élaboré selon le principe de priorisation basée sur les risques : les actions de court terme traitent les risques critiques et élevés identifiés à l'Atelier 4, tandis que les actions de moyen et long terme visent à construire une posture de sécurité mature et durable.

3.6.1 Actions prioritaires à court terme (0-3 mois)

Les quatre actions de court terme répondent à des vulnérabilités critiques directement exploitables par des attaquants. Le déploiement du MFA (authentification multifacteur) constitue la mesure individuelle au meilleur rapport coût/bénéfice : à un coût de mise en œuvre relativement faible, elle réduit drastiquement le risque de compromission de comptes, y compris les comptes administrateurs qui constituent la cible la plus dangereuse. La validation du PRA (Plan de Reprise d'Activité) en conditions réelles est indispensable pour s'assurer que le centre est réellement capable de récupérer ses données après une attaque ransomware.

3.6.2 Actions structurantes à moyen terme (3-12 mois)

Les actions de moyen terme visent à déployer des capacités de détection et de monitoring (SIEM), à mettre en œuvre la segmentation réseau — mesure technique fondamentale pour contenir la propagation d'un malware — et à garantir le chiffrement systématique des données. Le pentest externe est une action incontournable : seul un exercice d'intrusion réalisé par un prestataire indépendant permet d'objectiver le niveau de résistance réel de l'infrastructure face à un attaquant déterminé.

3.6.3 Maturité et amélioration continue à long terme (12-24 mois)

Les actions de long terme visent à inscrire la cybersécurité dans une démarche d'amélioration continue certifiée (ISO 27001) et à professionnaliser la gestion des vulnérabilités. La certification ISO 27001 représente un investissement significatif mais un signal fort envoyé aux patients, partenaires et régulateurs quant au sérieux de l'établissement dans la protection des données de santé. Le tableau de bord sécurité trimestriel assure quant à lui la visibilité de la direction sur les enjeux cyber, favorisant les prises de décision éclairées en matière d'investissements de sécurité.

Conclusion

4.1 Synthèse des résultats

Ce rapport a conduit une analyse de risques complète et structurée d'un centre d'imagerie médicale en appliquant le NIST Cybersecurity Framework 2.0 comme fil directeur méthodologique. La démarche en six ateliers successifs a permis d'aboutir à une vision claire et opérationnelle des risques cyber pesant sur cet établissement de santé. L'inventaire des actifs a mis en évidence la concentration des enjeux autour de quatre systèmes critiques (PACS, DPI, RIS, équipements d'imagerie), représentant le cœur opérationnel du centre et les cibles prioritaires des cyberattaquants. La cartographie des menaces a confirmé que le ransomware, l'exfiltration de données et la compromission de comptes privilégiés constituent les scénarios les plus dangereux pour un établissement de santé, combinant une probabilité d'occurrence élevée et un impact potentiellement catastrophique. L'évaluation selon la matrice $P \times I$ a hiérarchisé dix scénarios de risque, dont trois de niveau Critique nécessitant une réponse immédiate. Le plan de traitement des risques, aligné sur les six fonctions du NIST CSF 2.0, propose vingt-deux mesures de sécurité concrètes, réparties sur trois horizons temporels et associées à des indicateurs de succès mesurables. Ce plan constitue une feuille de route directement exploitable par le RSSI ou le directeur du centre.

4.2 Apport du NIST CSF 2.0 dans la gestion des risques médicaux

L'application du NIST CSF 2.0 à ce cas d'usage démontre la pertinence et l'efficacité de ce framework dans un contexte de santé. Sa structure modulaire en six fonctions — Govern, Identify, Protect, Detect, Respond, Recover — offre un langage commun entre les professionnels IT, les cliniciens, les gestionnaires et les régulateurs, facilitant la communication et le pilotage de la sécurité à tous les niveaux de l'organisation. Sa flexibilité d'adaptation à des structures de taille variable est particulièrement précieuse dans un secteur de la santé marqué par une grande hétérogénéité organisationnelle, allant du cabinet libéral individuel au grand CHU. L'introduction de la fonction Govern dans la version 2.0 représente une avancée majeure pour le secteur médical : elle positionne la cybersécurité comme une question de gouvernance stratégique, impliquant directement la direction des établissements, et non plus comme un simple sujet technique relégué au service informatique. Cette évolution est cohérente avec la prise de conscience croissante, au niveau des agences de régulation et des pouvoirs publics, de l'importance vitale de la cybersécurité pour la continuité des soins et la protection des patients.

4.3 Perspectives d'amélioration continue

La mise en œuvre du présent plan de sécurité ne constitue pas une fin en soi, mais le point de départ d'une démarche d'amélioration continue de la posture cybersécurité du centre d'imagerie. Plusieurs perspectives d'évolution méritent d'être soulignées. À court terme, la montée en compétences du personnel — radiologues, manipulateurs et personnel administratif — représente un levier d'amélioration majeur et sous-estimé. La culture de la cybersécurité ne se décrète pas ; elle se construit patiemment par des formations régulières, des simulations d'attaque et une communication claire sur les risques et les bons comportements à adopter. À moyen terme, l'adoption d'une approche Zero Trust Network Access (ZTNA) — principe selon lequel aucun utilisateur ni aucun équipement n'est considéré comme fiable par défaut, même à l'intérieur du réseau interne — représente une évolution architecturale structurante, particulièrement pertinente dans un contexte où les équipements biomédicaux connectés constituent des vecteurs d'attaque potentiels difficiles à maîtriser avec les approches périmétriques traditionnelles. À long terme, l'intégration progressive des technologies d'intelligence artificielle dans les outils de détection des menaces (IA pour l'analyse comportementale des utilisateurs, détection des

anomalies réseau) permettra d'améliorer la réactivité face à des attaques de plus en plus sophistiquées. Ces technologies, déjà utilisées dans les SIEM de nouvelle génération, trouvent une résonance particulière dans un secteur de la santé où l'IA est également déployée pour l'aide au diagnostic, créant de nouvelles surfaces d'attaque que les professionnels de la cybersécurité médicale devront apprendre à maîtriser. En définitive, la cybersécurité d'un centre d'imagerie médicale ne peut être appréhendée comme un projet ponctuel mais comme un processus continu, nourri par la veille sur les menaces émergentes, l'évaluation régulière des risques et l'engagement de la direction dans une culture de sécurité partagée par l'ensemble des acteurs de l'établissement.

References